Day 04

Hashing



Figure 1: echo “password” | md5sum

The following command takes the text “password”, generates its md5 hash (converts the plain text into a fixed length hash) and displays the hash.



Figure 2: echo “password” | sha256sum

The following command takes the text “password”, generates its sha256 hash (converts the plain text into a 256 bit) and displays the hash.

Password Cracking Demo

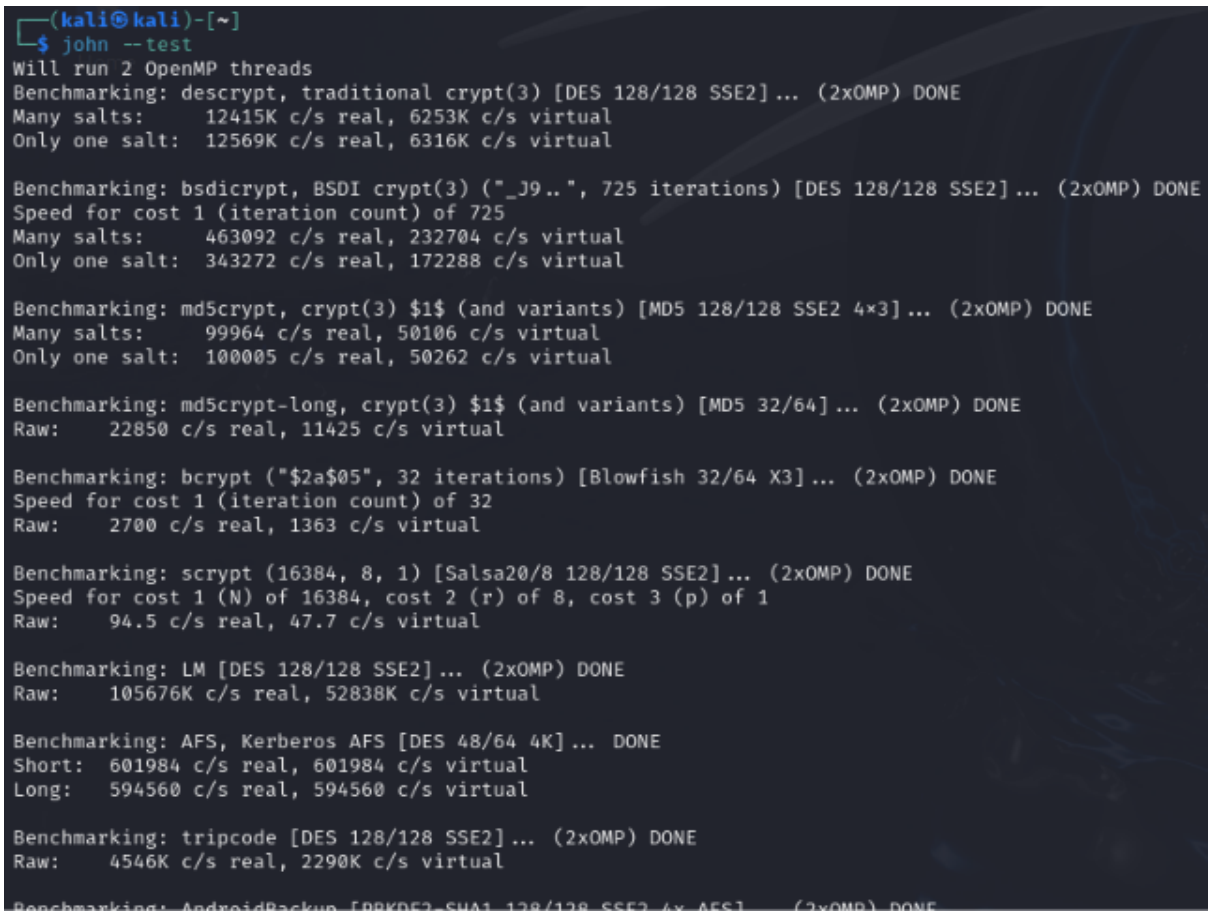


Figure 3: john --test

Runs a performance benchmark to measure how fast John The Ripper can test password hashes on your system.

Firewall Basics

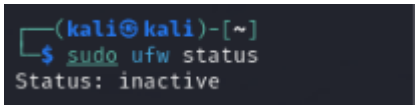


Figure 4: sudo ufs status

Displays the current status and rules of UFW (uncomplicated Firewall).

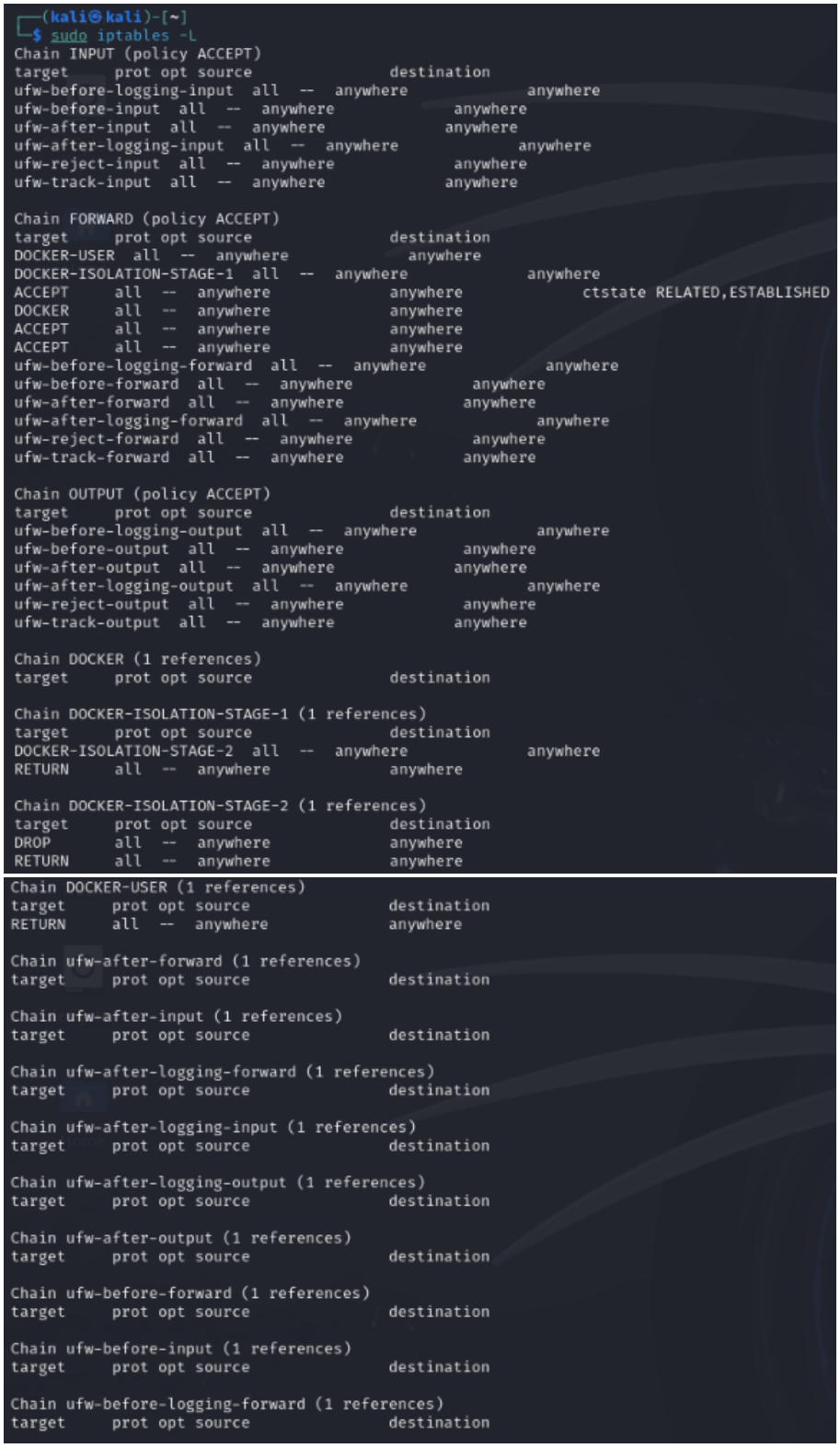


Figure 5: sudo iptables -L

Displays all the firewall rules configured through iptables.

User Attacks (Demo)



```
┌──(kali㉿kali)-[~]
└─$ hydra -help
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
 secret service organizations, or for illegal purposes (this is non-binding, these *** ig
nore laws and ethics anyway).

Syntax: hydra [[[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t
 TASKS] [-M FILE [-T TASKS]] [-w TIME] [-W TIME] [-f] [-s PORT] [-x MIN:MAX:CHARSET] [-c
TIME] [-ISOuvVd46] [-m MODULE_OPT] [service://server[:PORT][/OPT]]

Options:
  -R        restore a previous aborted/crashed session
  -I        ignore an existing restore file (don't wait 10 seconds)
  -S        perform an SSL connect
  -s PORT   if the service is on a different default port, define it here
  -l LOGIN or -L FILE  login with LOGIN name, or load several logins from FILE
  -p PASS  or -P FILE  try password PASS, or load several passwords from FILE
  -x MIN:MAX:CHARSET  password bruteforce generation, type "-x -h" to get help
  -y        disable use of symbols in bruteforce, see above
  -r        use a non-random shuffling method for option -x
  -e nsr    try "n" null password, "s" login as pass and/or "r" reversed login
  -u        loop around users, not passwords (effective! implied with -x)
  -C FILE   colon separated "login:pass" format, instead of -L/-P options
  -M FILE   list of servers to attack, one entry per line, ':' to specify port
  -o FILE   write found login/password pairs to FILE instead of stdout
  -b FORMAT specify the format for the -o FILE: text(default), json, jsonv1
  -f / -F   exit when a login/pass pair is found (-M: -f per host, -F global)
  -t TASKS  run TASKS number of connects in parallel per target (default: 16)
  -T TASKS  run TASKS connects in parallel overall (for -M, default: 64)
  -w / -W TIME  wait time for a response (32) / between connects per thread (0)
  -c TIME   wait time per login attempt over all threads (enforces -t 1)
  -4 / -6   use IPv4 (default) / IPv6 addresses (put always in [] also in -M)
  -v / -V / -d  verbose mode / show login+pass for each attempt / debug mode
  -O        use old SSL v2 and v3
  -K        do not redo failed attempts (good for -M mass scanning)
  -q        do not print messages about connection errors
  -U        service module usage details
  -m OPT    options specific for a module, see -U output for information
  -h        more command line options (COMPLETE HELP)
  server    the target: DNS, IP or 192.168.0.0/24 (this OR the -M option)
  service   the service to crack (see below for supported protocols)
  OPT       some service modules support additional input (-U for module help)

Supported services: adam6500 asterisk cisco cisco-enable cobaltstrike cvs firebird ftp[s]
 http[s]-{head|get|post} http[s]-{get|post}-form http-proxy http-proxy-urlenum icq imap[s
] irc ldap2[s] ldap3[-{cram|digest}md5][s] memcached mongodb mssql mysql nntp oracle-list
ener oracle-sid pcanywhere pcnfs pop3[s] postgres radmin2 rdp redis rexec rlogin rpcap rs
h rtsp s7-300 sip smb smtp[s] smtp-enum snmp socks5 ssh sshkey svn teamspeak telnet[s] vm
authd vnc xmpp

Hydra is a tool to guess/crack valid login/password pairs.
Licensed under AGPL v3.0. The newest version is always available at;
https://github.com/vanhauser-thc/thc-hydra
Please don't use in military or secret service organizations, or for illegal
purposes. (This is a wish and non-binding - most such people do not care about
laws and ethics anyway - and tell themselves they are one of the good ones.)
These services were not compiled in: afp ncp oracle sapr3 smb2.

Use HYDRA_PROXY_HTTP or HYDRA_PROXY environment variables for a proxy setup.
E.g. % export HYDRA_PROXY=socks5://l:p@127.0.0.1:9150 (or: socks4:// connect://)
     % export HYDRA_PROXY=connect_and_socks_proxylist.txt  (up to 64 entries)
     % export HYDRA_PROXY_HTTP=http://login:pass@proxy:8080
     % export HYDRA_PROXY_HTTP=proxylist.txt  (up to 64 entries)

Examples:
  hydra -l user -P passlist.txt ftp://192.168.0.1
  hydra -L userlist.txt -p defaultpw imap://192.168.0.1/PLAIN
  hydra -C defaults.txt -6 pop3s://[2001:db8::1]:143/TLS:DIGEST-MD5
  hydra -l admin -p password ftp://[192.168.0.0/24]/
  hydra -L logins.txt -P pws.txt -M targets.txt ssh
```

Figure 6: hydra -help

Displays the help documentation for Hydra, a network login password testing tool.

Hands on Task

```
┌──(kali㉿kali)-[~]
└─$ echo -n "azsxdc123" | sha256sum
ef1d6a357db47393e765acfe3a08787978440a0cee319edde352995206d0f978  -
```

Figure 7: Hashing password (azsxdc123) with sha256.

```
┌──(kali㉿kali)-[~]
└─$ nano wordlists.txt

┌──(kali㉿kali)-[~]
└─$ echo "azsxdc123" | sha256sum
a7cda88115278e3aba4ded6caef66b6e2a4d0a3ec90556efd95e605f88616110  -

┌──(kali㉿kali)-[~]
└─$ nano hash.txt

┌──(kali㉿kali)-[~]
└─$ nano hash.txt

┌──(kali㉿kali)-[~]
└─$ john --format=Raw-SHA256 --wordlist=wordlists.txt hash.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with no different salts (Raw-SHA256 [SHA256 128/128 SSE2 4x])
Warning: poor OpenMP scalability for this hash type, consider --fork=2
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
azsxdc123        (?)
1g 0:00:00:00 DONE (2026-11-14 10:55) 25.00g/s 975.0p/s 975.0c/s 1950C/s 123456
Warning: passwords printed above might not be all those cracked
Use the "--show --format=Raw-SHA256" options to display all of the cracked passwords reliably
Session completed.

┌──(kali㉿kali)-[~]
└─$ john --show --format=Raw-sha256 hash.txt
?:azsxdc123

1 password hash cracked, 2 left
```

Figure 8: Cracking a weak password

1. Created a wordlist (wordlists.txt) containing commonly used weak passwords, including my test password azsxdc123.
2. Generated the SHA-256 hash of azsxdc123 using echo "azsxdc123" | sha256sum (as shown in figure 7)
3. Created a text file named hash.txt and pasted the generated hash into it.
4. Used John the Ripper with the wordlist to crack the hash.
5. Used john --show to display the successfully recovered password.

Question - Explain difference between hashing & encryption.
Hashing converts data into a fixed length value that cannot normally be reversed to get the original data, whereas encryption converts data into a secret form that can be converted back using the right key.
Hashing is mainly used to store password securely, while encryption is used to protect messages, files and sensitive information.